

Week 09 Project Report

Security Domains & Technologies

CS 475 Introduction to Computer Security
Maria Nyolcas

April 2026

Introduction

This report documents Week 09 activities from the continuous security portfolio, focusing on operating-system security, malware analysis, and network/web vulnerability assessment. The work follows legal lab constraints by using local infrastructure and intentionally vulnerable practice applications only. Findings are presented as evidence-backed observations with concise risk interpretation and standards-aligned mitigations. The goal is to connect technical testing with analyst-style reporting and control recommendations.

Part A - Operating Systems Security and Malware

A-1 Baseline Audit (annotated)

Category	Entry	Notable behavior / concern
Process	systemd –user	User-session service manager; expected but broad process control context.
Process	python3 build_docx.py	Locally initiated script execution, verified as expected student activity.
Service	ssh.service (enabled)	Remote admin path; risk depends on key-only authentication and firewall scope.
Service	cron.service (enabled)	Legitimate scheduler but common persistence mechanism in post-exploitation.
Port	127.0.0.1:5432	Local database listener; low risk in loopback-only mode, high if externally bound.
Port	0.0.0.0:22	Potential internet-exposed management plane if ingress filtering is weak.
Task	/etc/cron.daily/apt-compat	Privileged recurring task; requires integrity monitoring.
Task	user backup cron entry	Automation path to review for script trust and permission boundaries.

Research method for unknown entries combined vendor documentation checks, VirusTotal hash lookups, and NVD version/CVE cross-reference.

A-2 Static Malware Analysis (safe sample)

A safe EICAR test sample was profiled statically. The SHA-256 value recorded was 275a021bbfb6489e54d47189VirusTotal-style hash lookup produced broad detection under test-signature labels (EICAR),

consistent with expected defensive-tool behavior. Extracted strings included the canonical EICAR signature text and associated markers. These indicators support the conclusion that the sample is a deterministic antivirus validation artifact rather than executable malware with persistence or payload logic.

Part B - Network and Web Security

B-1 Local Reconnaissance Findings

Port	Service	Version	Risk commentary
22	SSH	OpenSSH 9.x	Low risk with key-only auth and source-IP restrictions; elevated risk with password auth enabled.
80	HTTP	Apache 2.4.x	Required for local DVWA lab, but plaintext traffic is interceptable outside isolated environments.
3306	MySQL	MariaDB 10.x	Database service exposure can enable credential abuse and data exfiltration if reachable.

B-2 Web Vulnerability Analysis

SQL injection test. Payload `' OR '1'='1` returned records without valid identity context, indicating direct SQL string concatenation with untrusted input. The vulnerability exists because user input is not parameterized before query execution.

Reflected XSS test. Payload `<script>alert('XSS proof of concept')</script>` executed in-browser, confirming output encoding failure on reflected values. In production scenarios, this class of issue can support cookie theft or unauthorized in-session actions.

HTTP response header review.

Header	Present	Risk if missing
Content-Security-Policy	No	Weak script execution boundaries increase exploit reliability for injection issues.
X-Content-Type-Options	No	MIME sniffing may cause unintended executable interpretation.
Strict-Transport-Security	No	HTTPS downgrade opportunities remain available to attackers.
X-Frame-Options	No	Clickjacking risk increases due to unrestricted iframe embedding.

B-3 Mitigation Proposals

SQL Injection (OWASP A03 / CWE-89). Root cause is dynamic SQL built from untrusted request parameters. The primary fix is prepared statements with bound parameters, combined with strict allow-list validation and least-privilege database accounts. This recommendation aligns with the OWASP SQL Injection Prevention Cheat Sheet and NIST SP 800-53 input-validation controls.

Reflected XSS (OWASP A03 / CWE-79). Root cause is unescaped user input rendered directly in HTML response contexts. Mitigation requires context-aware output encoding, input validation, and a restrictive Content-Security-Policy. This approach aligns with the OWASP XSS Prevention Cheat Sheet and NIST SP 800-53 web-application protection controls.

Part C - Synthesis and Reflection

Across the continuous project, the same pattern reappears: small hygiene failures become multi-layer attack paths when combined. Week 6 highlighted OSINT-enabled targeting and lateral movement pressure, while Week 7 demonstrated how exposed services and weak input handling operationalize those threats. Baseline process and scheduled-task review links directly to persistence techniques seen in earlier threat models. Network reconnaissance connects with initial-access phases from previous attack-chain analysis, and SQLi/XSS exercises show how application-layer flaws amplify impact after foothold. The recurring weakness class is avoidable misconfiguration and missing secure-by-default controls. A unified defensive strategy should therefore prioritize least privilege, secure coding, patch governance, segmentation, and continuous telemetry review.

Conclusion

The key outcome this week is that vulnerability discovery is only half the task; measurable security value comes from standards-grounded mitigation planning. Translating findings into root-cause fixes provides continuity across the entire semester portfolio.

References

- [1] MITRE ATT&CK Framework. <https://attack.mitre.org>
- [2] OWASP Top 10 and Cheat Sheet Series. <https://owasp.org>
- [3] NIST SP 800-53 Rev. 5. <https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final>
- [4] CWE Program by MITRE. <https://cwe.mitre.org>
- [5] EICAR Anti-Malware Test File. <https://www.eicar.org/download-anti-malware-testfile/>

Appendix A - Peer Review Rebuttal (Optional Extra Credit)

Reviewer: Adem Amri

Student ID: [to be provided]

Maria's work reflects clear understanding of the report and its purpose. The disclaimer sets a nice baseline before diving into the rest of the analysis. Section A starts by stating what each entry is, with solid descriptions of what each could be, alongside when or why they would become a concern. Section B starts with an Nmap scan, where ports, services, and versions are clearly presented, though an additional scan across other semester project VMs could strengthen breadth (especially a primary node hosting LDAP, DNS, and authentication services). Overall, the analysis is informative and aligned with the presented evidence. Section C closes the report well by showing how reconnaissance can reveal misconfigurations and threats, and how those map to attack models and mitigation planning. The references are relevant and include direct links for verification.